



Login Page — Technical Documentation

Coresight Research Portal — Technical Documentation

Document version: 1.0

Generated: June 29, 2026

Classification: Internal — Engineering Reference

CONFIDENTIAL — INTERNAL USE ONLY — DO NOT DISTRIBUTE

This document contains proprietary information belonging to Coresight Research. Unauthorized disclosure, copying, or distribution is strictly prohibited.

Table of Contents

Login Page — Technical Documentation	1
Overview	3
URL / Route	3
Dependencies	4
UI Components	5
Session State Keys	7
Data Layer	8
Business Logic	9
Error Handling	11
Access Control List (ACL) / Permissions	11
Flowcharts	11

Source: `app/pages/login.py`

URL: `/login` (default landing page)

Purpose: Authenticate Coresight employees via OpenID Connect (OIDC) Single Sign-On (SSO) (all environments) or JSON Web Token (JWT) email/password (legacy production path when `IS_OIDC_ENV=False`)

Overview

The login page is the application entry point and the OIDC authorization-code callback handler. It supports two authentication modes gated by `core.auth_environment.IS_OIDC_ENV`:

Mode	When active	User experience
OIDC	<code>IS_OIDC_ENV=True</code> (current default)	"Sign in with Coresight" → redirect to Identity Provider (IdP) → callback with <code>?code=</code>
JWT	<code>IS_OIDC_ENV=False</code> (legacy)	Email + password form → WordPress JWT endpoint

Domain restriction: Only `@coresight.com` email addresses are accepted. Non-Coresight users are redirected to IdP logout to clear the SSO session.

The page performs substantial work at **module import time** (before `main()`): callback capture, handoff processing, fast cookie restore, and OIDC token exchange. The visible User Interface (UI) is only shown when the user is not already authenticated and no callback is in progress.

URL / Route

Route	Query params	Meaning
<code>/login</code>	—	Show login UI or fast-restore redirect
<code>/</code> (default)	Same as login	Default page in <code>main.py</code>
<code>/login</code>	<code>code</code> , <code>state</code>	OIDC authorization callback
<code>/login</code>	<code>error</code> , <code>error_description</code>	OIDC error callback
<code>/login</code>	<code>oidc_handoff=<key></code>	Cross-host login token handoff
<code>/login</code>	<code>oidc_post_logout=<key></code>	Post-logout return to original host
<code>/login</code>	<code>auth_error=cookie_write_failed</code>	Cookie handoff failure from <code>main.py</code>

Registered in `main.py`: `st.Page("pages/login.py", title="Login", url_path="login", default=True)`

Dependencies

Python modules

Import	Role
<code>core.auth_environment</code>	<code>IS_OIDC_ENV</code> , <code>is_production_deploy()</code>
<code>core.auth_manager</code>	<code>login_user</code> , <code>is_authenticated</code> , <code>get_current_domain</code> , <code>get_or_create_auth_flow_id</code> , <code>get_auth_flow_id</code> , <code>render_auth_cookie_handoff_redirect</code> , <code>_auth_request_meta</code>
<code>components.styles.hide_sidebar</code>	Hide Streamlit sidebar/chrome
<code>utils.server_logger</code>	<code>log_structured_error</code> , <code>log_error</code> , <code>log_warning</code> , <code>log_timing</code>
<code>requests</code>	OIDC token exchange, userinfo, JWT auth POST
<code>streamlit /</code> <code>streamlit.components.v1</code>	UI, SSO button parent-frame navigation
<code>dotenv.load_dotenv</code>	Environment loading

HyperText Markup Language (HTML)/CSS components (`app/components/`)

Loaded via `load_html_component(filename)` from `APP_DIR / "components"` :

File	Purpose
<code>login_layout.css</code>	Page layout styles (wrapped in <code><style></code> if needed)
<code>login_header.html</code>	Fixed top header bar (Coresight branding, external links)
<code>login_footer.html</code>	Footer widgets (social, terms, contact)

External integrations

Service	Endpoint / config	Usage
Coresight OIDC IdP	<code>IDP_AUTHORIZE_URL</code> (default <code>https://coresight.com/csr-idp/authorize</code>)	SSO redirect
Coresight OIDC token	<code>IDP_TOKEN_URL</code> (default <code>.../csr-idp/token</code>)	Code → tokens
Coresight userinfo	<code>IDP_USERINFO_URL</code> (default <code>.../wp-json/csr-idp/v1/userinfo</code>)	Email/profile fallback
Coresight IdP logout	<code>https://coresight.com/csr-idp/logout/</code>	Access-denied cleanup
WordPress JWT (legacy)	<code>{wp-json}/jwt-auth/v1/token</code> via <code>AUTH_URL</code> / <code>AUTH_URL_PAID</code>	Production password login
Azure CDN	Coresight logo image URL in overlays	Loading spinners

OIDC configuration constants

Constant	Value / source
<code>OIDC_CLIENT_ID</code>	<code>market-data</code>
<code>OIDC_CLIENT_SECRET</code>	Hardcoded in source (also sent in token exchange)
<code>OIDC_REDIRECT_URI</code>	<code>marketdata.coresight.com</code> (prod) or <code>marketdata-stg.coresight.com</code> (non-prod)
<code>OIDC_SCOPE</code>	<code>openid profile email</code> (env override <code>OIDC_SCOPE</code>)
<code>OIDC_STATE_MAX_AGE_SECONDS</code>	900 (15 min)
<code>OIDC_HANDOFF_MAX_AGE_SECONDS</code>	180
<code>POST_LOGIN_REDIRECT_DELAY_MS</code>	300

UI Components

Layout structure (`main()`)

```
login_layout.css (global)
login_header.html (fixed header)
└─ .content-wrapper.login-content
    └─ st.columns [2, 5, 2]
        └─ center column:
            └─ Welcome h4 + Portal h1
            └─ [OIDC] SSO section OR [JWT] form
            └─ "Contact Us" trial access footer
login_footer.html
```

OIDC mode UI elements

Element	Type	Behavior
Welcome heading	HTML <code><h4></code>	"Welcome to the Coresight Research"
Portal title	HTML <code><h1></code>	"Coresight Market Data Portal"
Premium member copy	<code>st.markdown</code>	Markdown + link to coresight.com/research
Sign in with Coresight	HTML <code><button id="csr-sso-btn"></code>	Click shows overlay, JS navigates to pre-built authorize URL
SSO overlay	<code>#csr-sso-overlay</code>	Logo + spinner + "Redirecting to SSO..."
<code>st.components.v1.html</code>	Hidden iframe script	Attaches click handler in parent document (bypasses iframe sandbox)
Error display	<code>st.error</code>	From <code>_oidc_login_error</code> session key (one-shot pop)
Trial access footer	HTML	Link to coresight.com/contact

JWT mode UI elements (legacy)

Element	Streamlit widget	Key
Email	<code>st.text_input</code>	default key
Password	<code>st.text_input(type="password")</code>	default key
Log in button	<code>st.button</code>	<code>login_button</code>
Auth error	<code>st.error</code>	<code>auth_error</code> session (cleared after display)

Loading overlays (module-level)

Overlay	Trigger	Message
<code>_make_loading_overlay</code>	Fast restore, OIDC callback	"Loading your workspace..." / "Completing sign-in..."
Callback spinner	<code>_oidc_cb_captured</code>	"Completing sign-in..."

CSS side effects

- Hides `[data-testid="stHeaderActionElements"]`
- Full-width red SSO button (`#d32f2f` / hover `#b71c1c`)
- Hides `stCustomComponentV1` container (height-0 iframe)

Session State Keys

OIDC flow

Key	Set when	Purpose
<code>__oidc_cb_code</code>	Callback capture	Authorization code
<code>__oidc_cb_state</code>	Callback capture	Encoded state payload
<code>__oidc_cb_error</code>	Callback capture	IdP error code
<code>__oidc_cb_error_desc</code>	Callback capture	IdP error description
<code>__oidc_cb_captured</code>	Callback capture	Flag: callback params stored
<code>__oidc_processing_code</code>	Processing start	In-flight code guard
<code>__oidc_processing_started_at</code>	Processing start	Stale processing detection (>8s)
<code>__completed_oidc_code</code>	Success	Dedup processed codes
<code>__completed_oidc_token_data</code>	Success	Cached normalized token data
<code>__oidc_exchange_result</code>	Token exchange	Session cache of raw token response
<code>__oidc_denied_codes_dict</code>	Access denied	Map code → True; skip reprocessing
<code>__completed_oidc_handoff_key</code>	Host handoff	Dedup handoff keys
<code>__completed_oidc_handoff_token_data</code>	Host handoff	Cached handoff token data
<code>__failed_oidc_handoff_key</code>	Handoff failure	Prevent retry loops
<code>__completed_oidc_post_logout_key</code>	Post-logout return	Dedup post-logout redirects
<code>__force_prompt_login</code>	(pop on use)	Force <code>prompt=login</code> on authorize URL
<code>__oidc_login_error</code>	Handoff/cookie failures	User-visible error message
<code>__logout_guard</code>	After logout	Block auto-restore from cookie
<code>__just_logged_out</code>	(pop)	Sets logout guard
<code>auth_flow_id</code>	SSO journey	Correlation ID (via <code>auth_manager</code>)

JWT flow (legacy)

Key	Purpose
<code>is_authenticating</code>	Button disabled + spinner label
<code>auth_error</code>	Display once then clear

Shared (post-login)

Key	Purpose
<code>authenticated</code>	Set by <code>login_user</code> / fast restore
<code>auth_data</code>	Full auth payload

Data Layer

Database

Table: `market_data_user_sessions`

Written by: `auth_manager.login_user()` → `AuthManager._store_session_in_db()`

Not read during login page execution — audit only.

```
INSERT INTO market_data_user_sessions
    (user_email, user_nicename, user_display_name, token, login_at, last_activity)
VALUES (:user_email, :user_nicename, :user_display_name, :token, NOW(), NOW())
```

Ephemeral file caches (`/tmp`)

Prefix	File pattern	TTL	Purpose
<code>return</code>	<code>_oidc_return_{hash}.json</code>	<code>OIDC_RETURN_CONTEXT_MAX_AGE_SECONDS</code>	Original request origin for cross-host handoff
<code>handoff</code>	<code>_oidc_handoff_{hash}.json</code>	<code>OIDC_HANDOFF_MAX_AGE_SECONDS</code>	Token data for <code>oidc_handoff</code> query param
<code>logout_return</code>	<code>_oidc_logout_return_{hash}.json</code>	<code>OIDC_RETURN_CONTEXT_MAX_AGE_SECONDS</code>	Post-logout origin return
<code>exchange</code>	<code>_oidc_xch_{hash}.json</code>	300s	Authorization code → token response dedup

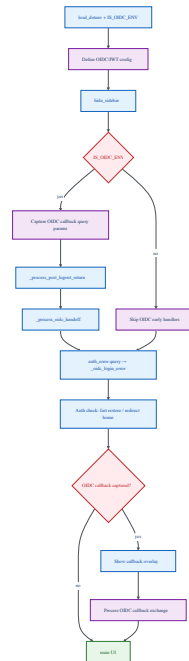
In-process caches (OIDC only)

- `_oidc_exchange_lock` — threading lock (25s acquire timeout)
- `_oidc_exchange_cache` — dict keyed by authorization code

Business Logic

Module initialization order

Module initialization order



OIDC authorization URL (`_build_authorize_url`)

1. Generate `nonce` , `code_verifier` (`cv`), timestamp
2. Encode state: `{nonce, cv, ru: redirect_uri, ts, rk?: return_key}`
3. Stash request origin in `/tmp` if allowed (`_stash_return_origin`)
4. Proof Key for Code Exchange (PKCE): `code_challenge=cv` , `code_challenge_method=plain`
5. Optional `prompt=login` if `__force_prompt_login`

OIDC callback processing

1. **Denied code check** — if code in `__oidc_denied_codes_dict` , meta-refresh to `/`
2. **Dedup** — if `__completed_oidc_code == code` , reuse cached token data
3. **In-progress** — if same code processing, wait/retry or complete from cache
4. **New code:**
 - Decode and validate state (`_decode_state_payload` , max age 900s)
 - `_exchange_code_for_tokens` with lock + triple cache (session, process, file)
 - `_build_token_data` — decode id_token JWT, optional userinfo fetch
 - `_maybe_redirect_oidc_handoff` if login started on different host (e.g. localhost)
 - `_complete_oidc_login`

`_complete_oidc_login`

1. Reject non-`@coresight.com` → mark code denied, IdP logout redirect, `st.stop()`
2. `login_user(...)` with email, token, id_token, wp_user_id

3. On success: clear OIDC transient keys, `render_auth_cookie_handoff_redirect("/home")`, `st.stop()`

Fast restore (already logged in)

Reads `auth_session` from `st.context.cookies` synchronously:

- Valid cookie → loading overlay → set session_state → `st.switch_page("pages/home.py")`
- Session_state auth without HTTP cookie → cookie handoff redirect
- OIDC: respects `__logout_guard` and `_auth_invalidated`

Cross-host handoff

When OIDC redirect URI is STG but user started on `localhost` :

1. Login captures origin in state (`rk` key)
2. After token exchange on STG, if origins differ → write handoff file, redirect to `{origin}/?oidc_handoff={key}`
3. Origin host `_process_oidc_handoff` consumes file and completes login locally

JWT authentication (legacy `_authenticate_user`)

Tries token endpoint with three payload encodings in order:

1. JSON wire with escaped quotes (`_send_json_wire`)
2. Raw JSON (`_send_json_raw`)
3. Form URL-encoded (`_send_form`)

Special handling for passwords containing quotes via `_escape_for_unslash` .

Error Handling

Scenario	User feedback	Log / recovery
OIDC <code>error</code> query param	<code>st.error</code> with description	Clears callback session keys
Invalid/expired state	"Invalid login state"	Clears processing marker
Token exchange non-200	<code>st.error</code> with payload	Retries file cache on <code>invalid_grant</code>
Exchange lock timeout	"Login timed out"	25s lock wait
Missing PKCE verifier	"Missing PKCE verifier"	—
Unresolved email from tokens	Contact support message	—
Non-Coresight email	IdP logout redirect (no message)	Code marked denied
<code>login_user</code> failure	<code>result.error_message</code>	—
Handoff expired	<code>_oidc_login_error</code>	<code>__failed_oidc_handoff_key</code>
Cookie write failed	Via <code>auth_error</code> query	Set in <code>main.py</code>
Page render exception	"Something went wrong"	<code>log_structured_error</code>
JWT bad credentials	"Incorrect username or password"	—
JWT non-Coresight	"Access restricted to Coresight employees only"	—

Access Control List (ACL) / Permissions

The login page itself has **no page-level ACL** — it is public. Post-login, access to other pages may be gated by `coreiq_page_access_control` on individual pages.

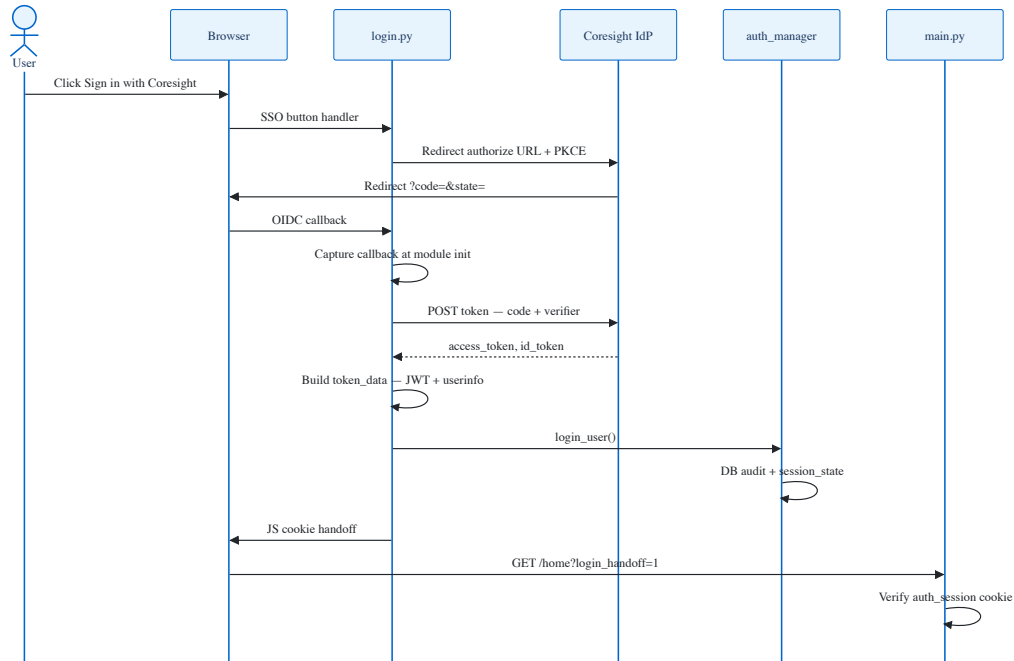
Hard gate at login: `user_email.lower().endswith("@coresight.com")` in both OIDC and JWT paths.

Flowcharts

OIDC login (happy path)

Standard SSO journey from button click through token exchange to cookie handoff and server verification.

Standard SSO journey from button click through token exchange to cookie handoff and server verification.



User interaction — SSO button

The SSO button injects parent-frame JavaScript to navigate to the IdP authorize URL after a brief overlay.

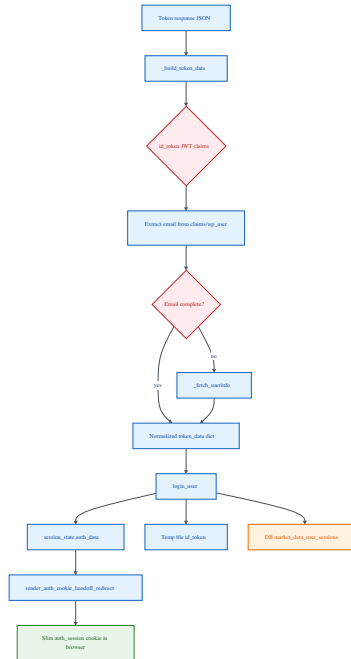
The SSO button injects parent-frame JavaScript to navigate to the IdP authorize URL after a brief overlay.



Data flow — token to session

Token response is normalized to user identity, written to session state and audit Database (DB), then slim cookie is set in the browser.

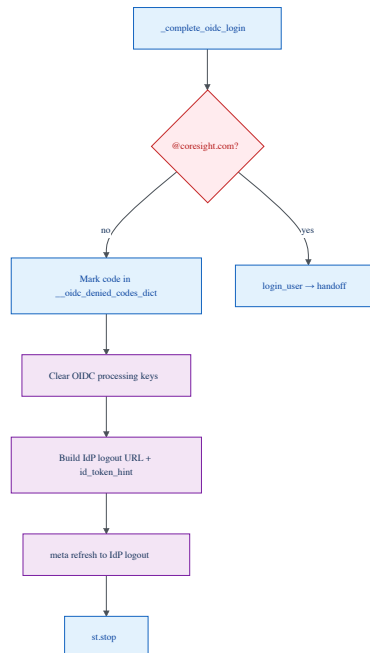
Token response is normalized to user identity, written to session state and audit Database (DB), then slim cookie is set in the browser.



Error handling — access denied

Non-@coresight.com emails trigger IdP logout and block reprocessing of the denied authorization code.

Non-@coresight.com emails trigger IdP logout and block reprocessing of the denied authorization code.



Key code references

Function / block	Lines (approx.)	Description
OIDC config	29–48	IdP URLs, client, redirect
<code>_build_authorize_url</code>	427–455	SSO URL builder
<code>_exchange_code_for_tokens</code>	469–563	Locked token exchange
<code>_complete_oidc_login</code>	672–769	Domain check + login_user
Callback capture	900–921	Module-level query capture
Fast restore	953–1087	Cookie → home redirect
OIDC callback processing	1109–1219	Full exchange pipeline
<code>main()</code> UI	1238–1501	Visible login form
JWT <code>authenticate_user</code>	863–893	Legacy password auth

Related pages

Page	Relationship
<code>main.py</code>	Default route, <code>login_handoff</code> verification, logout routing
<code>logout_bridge.py</code>	Clears session; may redirect back with <code>oidc_post_logout</code>
<code>home.py</code>	Post-login destination (<code>/home</code>)

Generated from source analysis of `app/pages/login.py`. MCP `code-review-graph` was unavailable; documentation based on direct file reads.